



OPTIMAL

WHITEPAPER · SEPTEMBER 2026

One program. Three package shapes.

A blueprint for architecting FedRAMP authorization packages across 20x, Rev5 under the Consolidated Rules for 2026, and the legacy artifacts agencies and the DoD equivalency process still require.

FedRAMP 20x

Rev5 · CR26

Legacy · Equivalency

The rules moved

CR26 effective **Jul 4, 2026**, mandatory **Jan 1, 2027**. SSP and POA&M retired. Rev5 sunset **Dec 31, 2028**.

The buyers didn't

AOs still request the **SSP and POA&M**. The DoD equivalency BOE still requires them, **100% implemented, all items closed**.

Written by Ryan Gutwein

// GOOPTIMAL.IO



The problem: the program modernized; the buyers haven't

FedRAMP has rebuilt itself. The JAB is gone. FedRAMP 20x has been granting authorizations since the 2025 pilots. The Consolidated Rules for 2026 took effect on July 4, 2026 and become mandatory for all stakeholders on January 1, 2027. Under those rules the System Security Plan and the POA&M are retired artifacts: the Security Decision Record replaces them, evidence is machine-readable, and validation is persistent rather than point-in-time. FedRAMP stops accepting new Rev5 applications on June 11, 2027 and plans to sunset existing Rev5 authorizations by December 31, 2028.

The buyers have not moved at the same speed. Agency authorizing officials still ask for the SSP and the POA&M, and are expected to keep asking after providers stop producing them. Procurement language still says "FedRAMP Authorized (Rev5)." And for cloud services sold to defense contractors handling CUI, the DoD's FedRAMP Moderate equivalency memo defines the required body of evidence as exactly the legacy package: SSP, SAP, SAR, and POA&M, covering 100% of the Moderate baseline, assessed by a 3PAO, with every POA&M item closed, under DCMA DIBCAC oversight.

That is the split: the modern rules retire the exact documents the legacy buyers still require. Build only for the new world and you cannot sell into the old one. Build only the old package and you are building on a foundation with a published sunset date. Most providers will spend 2026 through 2028 needing both.

The answer is not two or three parallel compliance programs. It is one security program, one evidence layer, and package emitters that produce whatever shape the buyer requires.

Program modernization	2024 JAB dissolved; unified "FedRAMP Authorized"	2025 20x Phase 1 pilots grant first authorizations	JUL 4 2026 Consolidated Rules effective; SSP & POA&M retired	JAN 1 2027 CR26 mandatory for all stakeholders	JUN 11 2027 Last new Rev5 applications accepted	DEC 31 2028 Planned sunset of Rev5 authorizations
Buyer reality	AGENCY AOs Still request SSP and POA&M, and are expected to keep doing so	PROCUREMENT Contract language still cites Rev5 artifacts by name	DoD EQUIVALENCY BOE defined as SSP + SAP + SAR + POA&M, 100% of Moderate, all POA&Ms closed	DIBCAC Validates DFARS 7012/7020 compliance against that legacy-shaped BOE	REV5 RIDERS Agencies keep issuing ATOs on existing Rev5 packages until sunset	LAG Contract templates historically trail rule changes by years

FIGURE 1 *Two clocks running. The rules retire the documents on the top lane's schedule; the buyers on the bottom lane still ask for them.*

Three package shapes, one program

These are not three security programs. They are three shapes the same underlying facts must take, depending on who is buying.

	FedRAMP 20x The destination	Rev5 under CR26 The bridge	Legacy & equivalency The buyer reality
What it is	Certification against 46 Key Security Indicators, Classes A–D, sponsorless paths available	Existing Rev5 authorizations operating under the Consolidated Rules for 2026	What many AOs still request, plus the DoD FedRAMP Moderate equivalency pathway for DFARS 7012
Core record	SDR with KSI summaries, human-readable + JSON	SDR with control summaries; SSP and POA&M retired; VDR/VER for vulnerabilities; configuration guides	SSP, SAP, SAR, POA&M , monthly ConMon deliverables
Evidence style	Machine-readable measures, persistent validation, class-scaled metric history	Same direction as 20x: continuous monitoring broadened, availability reporting added	Narrative documents plus point-in-time assessment evidence; equivalency demands 100% of Moderate with all POA&Ms closed
Assessment	Independent assessor at least yearly (Classes B–D); assessor validates measures and automation	3PAO annual assessment continues under updated rules	3PAO assessment; DCMA DIBCAC validates the contractor side
Clock	Open now; Phase 3 formalizes wide-scale Low and Moderate adoption	Mandatory Jan 1, 2027; no new Rev5 applications after Jun 11, 2027	Persists until buyers and the DoD memo move; Rev5 riders end with the Dec 31, 2028 sunset

FIGURE 2 *The three package shapes. Same security program, three different outputs.*

Which shape do you owe, and when

Track selection is a sales question before it is a compliance question: it follows from who signs, or relies on, your authorization.

Who is the buyer relying on this package?

Cloud-native seller, no agency sponsor

Go straight to 20x. Pick the class from the data you handle; start metric history now, since Class B and C history cannot be backfilled.

Federal agency riding an existing Rev5 ATO

Operate the authorization under CR26: stand up the SDR, adopt VDR/VER, keep serving AOs who still ask for legacy documents while the grace periods run.

Defense contractors under DFARS 7012

Deliver the equivalency body of evidence: 100% of the Moderate baseline, 3PAO-assessed, SSP + SAP + SAR + POA&M with every item closed. Watch for the memo to modernize; do not bet on it.

Selling into more than one of these? That is the normal case, and it is why the blueprint below builds the evidence layer once and emits each shape from it, instead of maintaining parallel packages by hand.

FIGURE 3 Buyer determines shape. Multiple buyers determine the architecture.

The blueprint: one evidence layer, three emitters

Everything in every package shape is a claim about the same system. The architecture that survives 2026 through 2028 stores those claims once, with evidence, and renders them into whatever document a buyer requires.

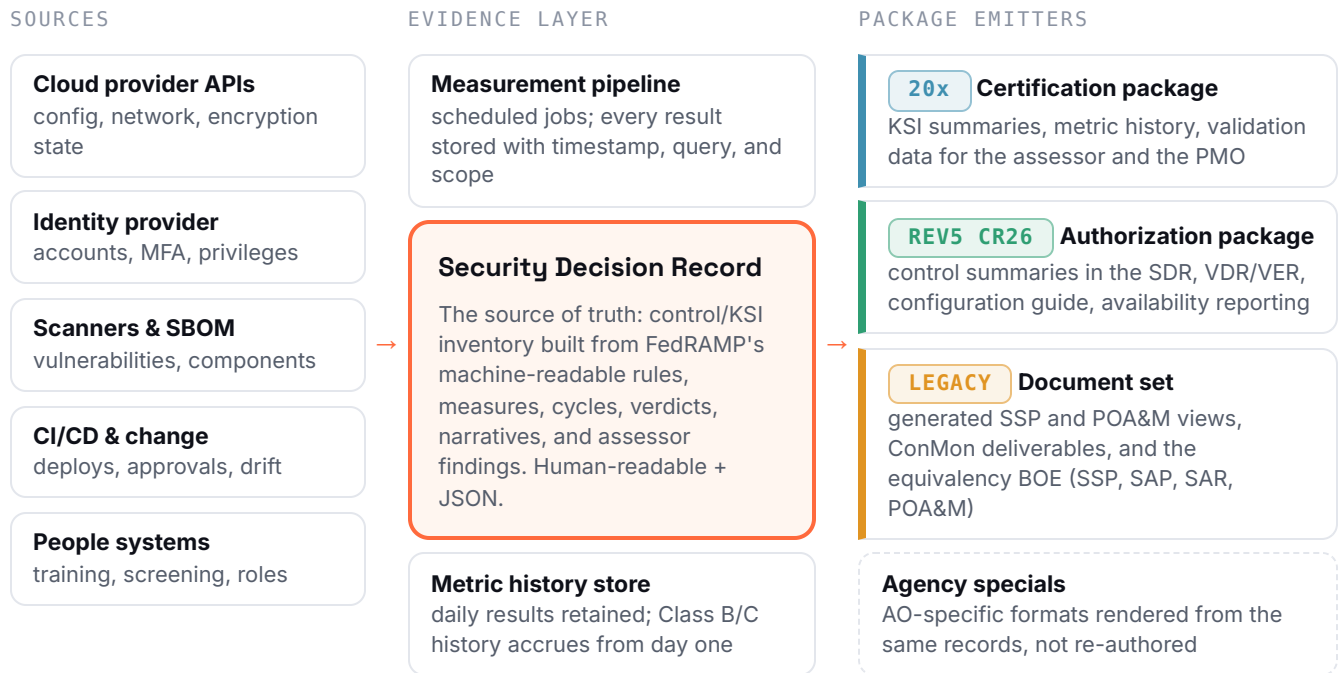


FIGURE 4 The blueprint. Documents are outputs of the evidence layer, never parallel sources of truth.

Principles that make it work

- **Build the inventory from the machine-readable rules.** FedRAMP publishes the Consolidated Rules as versioned JSON with KSI-to-800-53 mappings. Generate your control/KSI inventory from that file and diff it on every release.
- **Documents are rendered, not written.** The legacy SSP a DoD prime requests and the SDR your assessor validates must disagree about nothing, because both are views of the same records.
- **Every claim carries its evidence.** A measure result stores what ran, when, against what scope. That is what turns an assessor's verification into a formality instead of an excavation.
- **Start the metric clock immediately.** Class B requires 30-day summaries with up to a year of history; Class C requires a year of daily data. Neither can be created after the fact.

The way ahead

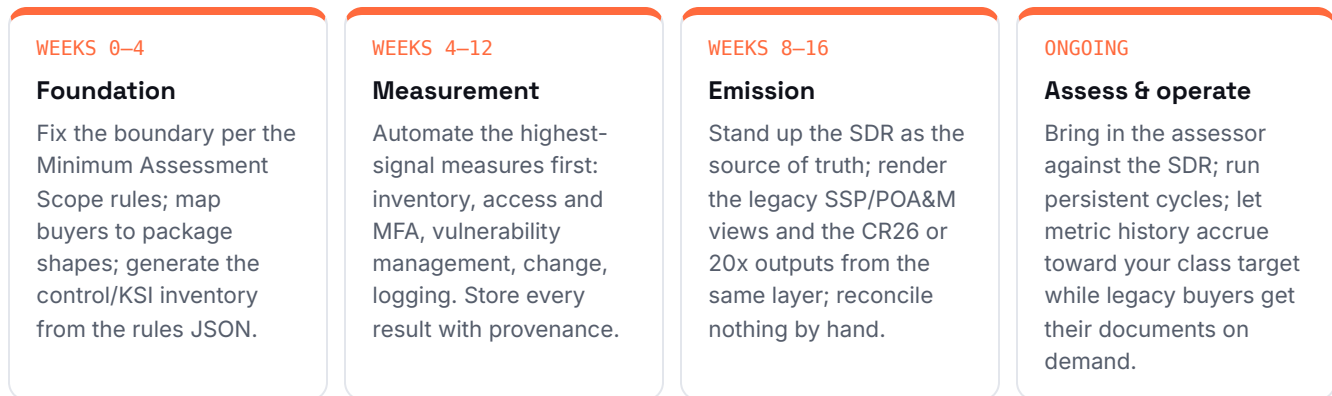


FIGURE 5 Sequencing. Measurement before emission; emission before assessment.

Where this goes wrong

- **Writing the SSP first** and reverse-engineering evidence to match it, which guarantees the documents and the system disagree.
- **Maintaining parallel packages by hand.** Two documents describing one control will drift; an assessor or a DIBCAC reviewer will find the drift.
- **Starting metrics at assessment time.** The history requirement is the quiet blocker in every class conversation.
- **Treating equivalency as a lesser FedRAMP.** It is stricter where it counts: 100% of the baseline, no open POA&Ms, and a contractor-facing BOE that gets audited.

Build the packages once

Architecting for 20x, operating a Rev5 authorization under the 2026 rules, or facing an equivalency ask from a defense prime? Optimal designs and builds authorization packages around evidence that runs on its own: the measurement pipeline, the Security Decision Record, and the legacy documents rendered from it. Schedule a 30-minute conversation at calendly.com/ryan-gooptimal/30min.

Sources

FedRAMP Consolidated Rules for 2026: fedramp.gov/2026/rules/ · Machine-readable rules: github.com/FedRAMP/rules · What's changing for Rev5: fedramp.gov/2026/providers/updates/changes/ · 20x Key Security Indicators: fedramp.gov/2026/providers/20x/key-security-indicators/ · 20x Assurance and Package: fedramp.gov/2026/providers/20x/ · DoD FedRAMP Moderate Equivalency memo (December 2023), DFARS 252.204-7012 · Timelines as published September 2026; verify current dates against fedramp.gov before committing plans.

ABOUT OPTIMAL

Optimal secures and governs AI and cloud systems wherever regulated data lives. Founded by **Ryan Gutwein**, a nine-year Air Force veteran with active FedRAMP 3PAO assessment contracts and operational experience across FedRAMP, DoD RMF/eMASS, DISA STIGs, CMMC, and DevSecOps. Optimal, LLC is an SBA-certified Service-Disabled Veteran-Owned Small Business (CAGE 14HQ0). goptimal.io